

HackerDNA - ClearDesk Write-up

Documentado por Milton de Jesus Melo

Informações do Laboratório (<https://hackerdna.com/labs/cleardesk>)

- Plataforma: HackerDNA
- Categoria: IDOR, API Security, Path Transversal, Access Control, Privilege Escalation
- Dificuldade: Médio
- Flags: 2

Objetivo

O laboratório ClearDesk, da HackerDNA, possui duas flags para captura: uma acessível com privilégios de usuário comum explorando a vulnerabilidade IDOR e outra que exige acesso administrador na plataforma.

NMAP

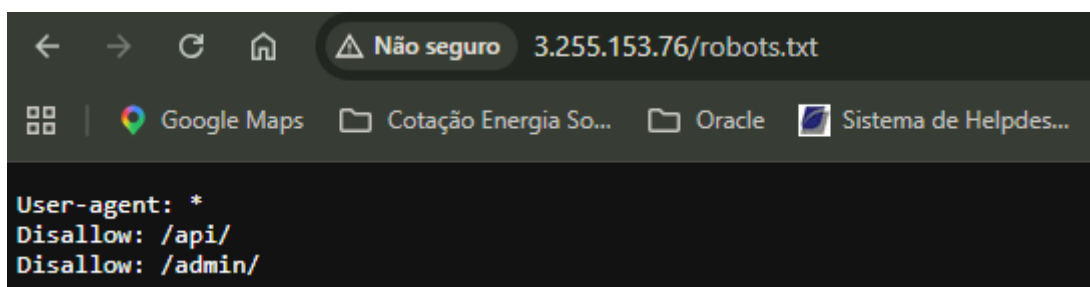
A enumeração inicial com Nmap identificou dois serviços HTTP expostos nas portas 80/TCP e 8080/TCP, executando respectivamente Nginx e Unicorn.

```
hacker:~$ nmap -sV 3.255.153.76
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-15 17:28 +0000
Nmap scan report for localhost (3.255.153.76)
Host is up (0.0000040s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http   nginx 1.28.2
8080/tcp  open  http   Unicorn

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.52 seconds
hacker:~$
```

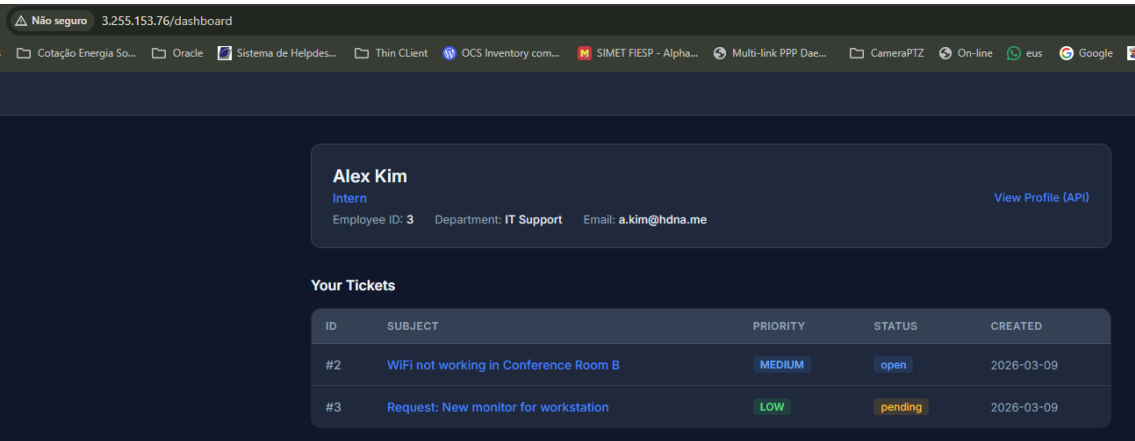
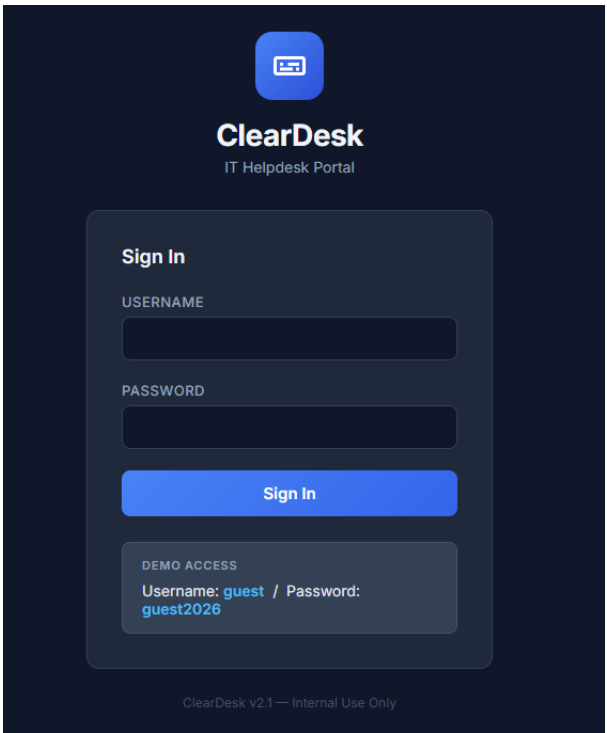
Robots.txt

A análise do arquivo robots.txt revelou dois diretórios relevantes para a superfície de ataque da aplicação: /api/ e /admin/. Embora destinados a mecanismos de indexação, esses caminhos forneceram informações úteis para a enumeração da aplicação.



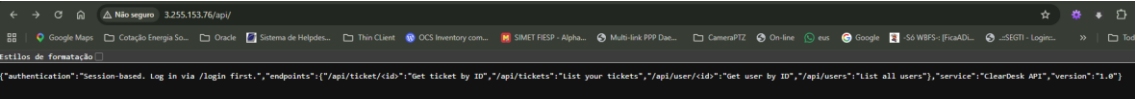
```
User-agent: *
Disallow: /api/
Disallow: /admin/
```

Usando os dados de acesso visitante disponíveis na página de login foi possível acessar o painel principal da aplicação web.



Exploração da API

A partir desse acesso inicial, foi possível explorar as funcionalidades da API identificada durante a análise do arquivo robots.txt.



A API apresentava uma vulnerabilidade do tipo **Insecure Direct Object Reference (IDOR)**, permitindo o acesso a objetos por meio da alteração de identificadores numéricos sem

validação adequada de autorização. Como consequência, foi possível consultar informações de usuários e tickets pertencentes a outros perfis.

```
"users":[{"department":"IT Administration","email":"s.chen@hdna.me","id":1,"name":"Sarah Chen","role":"IT Director"}, {"department":"Engineering","email":"e.robert@hdna.me","id":2,"name":"Mike Roberts","role":"Senior Developer"}, {"department":"IT Support","email":"s.king@hdna.me","id":3,"name":"Alan King","role":"Admin"}, {"department":"Design","email":"j.ling@hdna.me","id":4,"name":"Jordan Lee","role":"UI Designer"}]}
```

Obtenção da User Flag

A primeira flag foi conquistada ao extrair os dados do ticket 1, através do link <http://3.255.153.76/api/ticket/1>

```
"created":"2026-03-08T09:15:00Z","description":"Annual security audit findings: \u201cCONFIDENTIAL\u201c, \u201cuserflag: [REDACTED]\u201c","id":1,"owner_id":1,"priority":"critical","status":"open","subject":"Confidential: Annual Security Audit"}
```

Escalonamento de privilégios

Durante a análise dos tickets acessíveis via IDOR, foi identificada uma solicitação de redefinição de senha do usuário administrador. O histórico do chamado continha informações sensíveis expostas em texto claro, incluindo a nova credencial de acesso.

```
"created":"2026-03-08T16:45:00Z","description":"Temporary admin password has been reset per policy. New credentials: admin / [REDACTED]. Please change after first login.\u201c, \u201cAlso: the nightly backup job is failing to read [REDACTED] (permission denied). Please check file permissions after login. \u201c\u201c2026 IT Security Team\u201c","id":8,"owner_id":1,"priority":"high","status":"resolved","subject":"Password Reset: Admin Portal Access"}
```

Após encerrar a sessão do usuário visitante, foi realizado login com as credenciais administrativas obtidas durante a exploração dos tickets. Neste painel o usuário admin possui uma tela de console com acesso aos arquivos de log do servidor.

Sarah Chen

IT Director

Employee ID: 1 Department: IT Administration Email: s.chen@hdna.me

View Profile (API)

Your Tickets

ID	SUBJECT	PRIORITY	STATUS	CREATED
#1	Confidential: Annual Security Audit	CRITICAL	open	2026-03-08
#8	Password Reset: Admin Portal Access	HIGH	resolved	2026-03-09

Admin Panel

Log Viewer

View server log files for diagnostics and monitoring.

app.log

errors.log

access.log

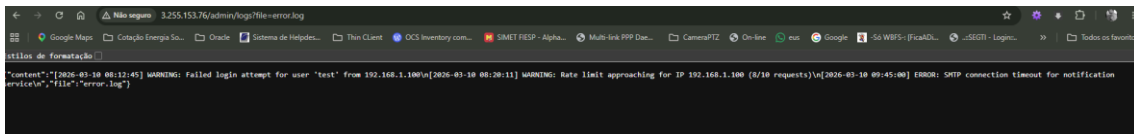
User Management

View and manage employee accounts.

[All Users](#)

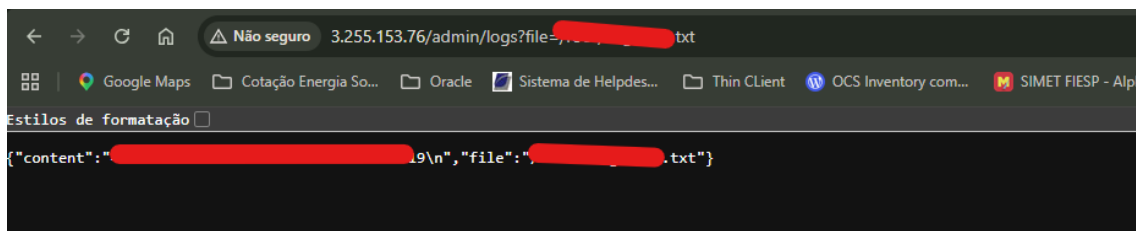
Exploração da LFI

O painel administrativo disponibilizava uma funcionalidade de visualização de logs. Através da manipulação do parâmetro responsável pela seleção dos arquivos, foi identificada uma vulnerabilidade **Local File Inclusion (LFI)**, permitindo a leitura arbitrária de arquivos presentes no sistema operacional.

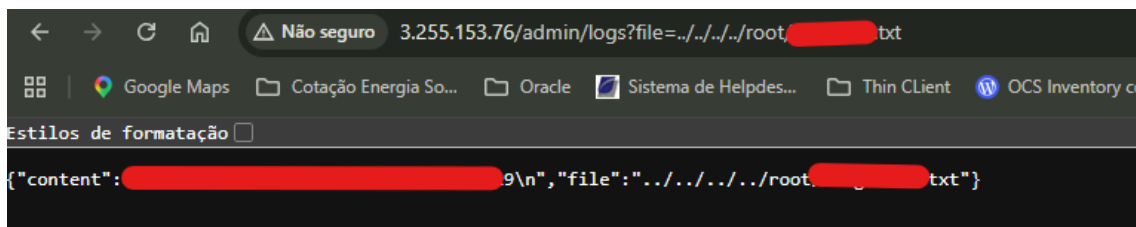


Obtenção da Root Flag

A exploração da vulnerabilidade permitiu a leitura do arquivo contendo a root flag.



Além da vulnerabilidade LFI, o mesmo mecanismo permitia exploração por meio de sequências ../, caracterizando uma vulnerabilidade de **Patch Traversal**, possibilitando navegar fora do diretório previsto pela aplicação e acessar arquivos sensíveis do sistema.



Skills Demonstradas

- Reconhecimento e Enumeração;
- Análise de Aplicações Web;
- Análise de APIs REST;
- Exploração de IDOR;
- Escalonamento de Privilégios;
- Local File Inclusion (LFI);
- Patch Traversal;
- Análise de Controle de Acesso.

Conclusões

O laboratório demonstrou como falhas aparentemente independentes podem ser encadeadas para comprometer completamente uma aplicação. A exposição de endpoints através do robots.txt facilitou a enumeração inicial, enquanto a vulnerabilidade IDOR permitiu acesso indevido a informações sensíveis. Essas informações possibilitaram a obtenção de credenciais administrativas, culminando na exploração de vulnerabilidades LFI e Directory Traversal para acesso a arquivos críticos do sistema.

O exercício reforça a importância da validação de autorização em APIs, da proteção de informações sensíveis em chamados de suporte e da implementação adequada de controles de acesso a recursos do sistema.

Lições Aprendidas

- Identificação de endpoints sensíveis através de técnicas de enumeração passiva.
- Exploração de vulnerabilidades IDOR em APIs REST.
- Análise de dados expostos indevidamente em sistemas de chamados.
- Escalonamento de privilégios por meio de credenciais comprometidas.
- Exploração de vulnerabilidades Local File Inclusion (LFI).
- Exploração de Directory Traversal para leitura arbitrária de arquivos.
- Importância da aplicação do princípio do menor privilégio e da validação de autorização em APIs.